

تقرير الأوفستات الأخطر — ANOGS Anti-Cheat

الأوفستات التي يؤدي تعطيلها لإسقاط 100% من نظام مكافحة الغش

لماذا هي خطيرة؟ ماذا يحصل إذا تعطلت؟ هل يُكتشف المهاجم؟

تقرير دفاعي — تحليل هيكلي فقط — بدون محتوى bypass

♦ bypass by Hdanh | ♦ made by @Nopermcc

الخلاصة — 5 أوفستات = موت كامل

النتيجة الصادمة: من أصل 10,121 دالة و 2.87 ميغابايت من الكود، هناك 5 أوفستات فقط تعطيلها = إسقاط 100% من نظام مكافحة الغش. والأخطر: لا يوجد أي آلية تكشف تعطيلها — المهاجم يصبح غير مرئي تماماً.*

#	الأوفست	الاسم	التأثير	هل يُكتشف؟
1	0x0373e8	بوابة الإبلاغ الوحيدة	صمت 100% — كل الكشف يتعطل	لا
2	0x29bc38	مفتاح قتل القناة	قتل COREREPORT نهائياً	لا
3	0x0376a0	المورّع الرئيسي	إسقاط كل الأحداث قبل المعالجة	لا
4	0x0a1414	بوابة Syscall الخام	تعطيل النقل المضاد لل hook	لا
5	0x29bc10	جدول البوابات (7 slots)	إسقاط فئات كشف مختارة	لا

لماذا لا يُكتشف؟ تحققنا من ثلاثة أشياء:

- لا يوجد integrity check — لا أي دالة تفحص سلامة كود هذه الدوال الخمس
- لا يوجد watchdog — لا أي مؤقت يتحقق أن التقارير لا تزال تُرسل
- لا يوجد heartbeat — السيرفر لا يعرف إذا توقف العميل عن الإبلاغ

التفصيل الكامل — أوفست بأوفست

1

0x0373e8 — بوابة الإبلاغ الوحيدة (Report Emit)

تعطيل = صمت 100%

SPOF

CRITICAL

ما هي هذه الدالة؟

هذه هي الدالة الوحيدة في كل البايناري التي ترسل نتائج الكشف إلى السيرفر. كل أنظمة الكشف — بدون استثناء — تمر عبرها:

نظام الكشف	يمر عبر 0x0373e8
كشف (sysctl P_TRACED) Debugger	نعم — الطريق الوحيد

كشف (dyld image scan) Injection	نعم — الطريق الوحيد
كشف (access/statfs) Jailbreak	نعم — الطريق الوحيد
كشف ObjC Swizzle	نعم — الطريق الوحيد
كشف DL-Probe (dlopen/dlsym)	نعم — الطريق الوحيد

تحققنا: لا يوجد قناة إبلاغ بديلة. فقط دالتان في كل البايناري تشير إلى "COREREPORT string" — هذه الدالة (0x0373e8) ودالة التسجيل (0x0371e0). لا قناة ثانية، لا fallback، لا backup.

لماذا هي هشة؟ — 4 نقاط إسقاط صامت

```

=== الدالة الأخطر في كل البايناري - sub_0373e8 ===

0x0373f4: cbz x0, #0x37454 ← arg0 == NULL نقطة إسقاط #1: إذا
→ error ولا log صامت - return

0x0373fc: cbz x20, #0x37454 ← vtable ptr == NULL نقطة إسقاط #2: إذا
→ صامت - الكائن غير مهياً return

0x037420: cbz x0, #0x37454 ← COREREPORT lookup نقطة إسقاط #3: إذا فشل
→ صامت - القناة غير مسجلة return

0x037438: cbz x0, #0x37454 ← channel resolve نقطة إسقاط #4: إذا فشل
→ صامت - القناة معطلة return

0x037454: ret ← الخروج الصامت المشترك
log, counter, retry, alert: لا يوجد
التقرير يختفي بصمت = كأنه لم يُكتشف شيء

```

ماذا يحصل إذا تعطلت؟

السيناريو: إذا تعطلت هذه الدالة بأي شكل:

- كل أنظمة الكشف تستمر بالعمل محلياً — تكتشف debugger, injection, jailbreak
- لكن لا شيء يصل السيرفر — كل النتائج تُسقط قبل الإرسال
- السيرفر يرى: "هذا اللاعب نظيف 100%" — وهو في الحقيقة يغش
- لا يوجد أي آلية تكشف أن التقارير توقفت (لا heartbeat، لا watchdog)

النتيجة: المهاجم غير مرئي — 100% undetected

هل يوجد فحص سلامة لهذه الدالة؟

لا — تحققنا:

- بحثنا في كل قسم DATA عن أي مرجع بيانات للعنوان 0x0373e8 — لا يوجد
- لا أي دالة تحسب hash أو CRC لكود هذه الدالة
- لا أي import لدوال تجزئة (CC_SHA، CC_MD5) مرتبط بفحص الكود
- الدالة غير محمية بأي شكل — لا تشفير، لا obfuscation، لا guard page

كيف نحصّن؟

1. إضافة قناة إبلاغ ثانية مستقلة تماماً (مسار كود مختلف، بروتوكول مختلف)
2. تحويل كل cbz → ret إلى cbz → error_counter + fallback_emit

3. إضافة heartbeat: السيرفر يتوقع تقرير كل X ثانية — غيابه = إنذار
4. فحص سلامة كود الدالة دورياً (hash check كل 30 ثانية)

2

0x29bc38 — مفتاح القتل (Channel Kill-Switch)

بايت واحد = موت القناة

KILL-SWITCH

CRITICAL

ما هو هذا الأوفست؟

هذا ليس دالة — بل بايت واحد في DATA__ عند العنوان 0x29bc38. هذا البايت هو مفتاح تشغيل/إيقاف لقناة COREREPORT بالكامل. إذا 0 = القناة ميتة. إذا 0 ≠ 0 → القناة تعمل.

كيف يعمل؟

```
=== تسجيل القناة - sub_0371e0 داخل ===  
  
0x037208: ldrb w8, [x23, #0xc39] ← من 0x29bc39 init_once flag قراءة  
0x03720c: tbz w8, #0, #0x37220 ← إذا لم يُهيأ بعد → اذهب وهَيِّئ  
0x037214: ldrb w0, [x8, #0xc38] ← من 0x29bc38 channel_enable قراءة  
0x037218: cbnz w0, #0x3724c ← إذا 0 ≠ 0 → القناة شغالة → استمر  
0x03721c: b #0x373cc ← الكامل SKIP → إذا 0 == 0 → القناة ميتة  
  
--- ما الذي يكتب 0 في هذا البايت؟ ---  
:آلية "الموت البطيء" بعد 3 فشلات  
  
0x0373a8: ldr w9, [x8, #0xc3c] ← من 0x29bc3c retry_counter قراءة  
0x0373ac: add w10, w9, #1 ← counter++  
0x0373b0: str w10, [x8, #0xc3c] ← حفظ العداد الجديد  
0x0373b4: cmp w9, #3 ← هل وصل 3 فشلات؟  
0x0373b8: b.lt #0x373cc ← أقل من 3 → حاول مرة أخرى  
  
0x0373c4: strb wzr, [x8, #0xc38] ← كتابة 0 = قتل القناة نهائياً  
لا يوجد مؤقت إعادة تفعيل  
recovery لا يوجد آلية  
القناة ميتة حتى إعادة تشغيل التطبيق
```

لماذا هذا خطير جداً؟

هذا البايت الواحد يتحكم بكل تدفق الإبلاغ. ملاحظات حرجية:

1. بايت واحد في DATA__ — قسم DATA__ قابل للقراءة والكتابة (rw-). لا يحتاج تغيير كود — فقط بيانات.
2. التعطيل الذاتي: 3 فشلات شبكة متتالية (timeout, DNS fail) كافية لقتل القناة — بدون أي هجوم.
3. لا recovery: بمجرد كتابة 0 → القناة ميتة نهائياً. لا مؤقت، لا retry، لا إعادة تهيئة.
4. لا حماية: البايت في DATA__ العادي — لا vm_protect، لا guard page، لا integrity check.

هل يُكتشف المهاجم؟

لا — لثلاثة أسباب:

- كتابة 0 في بايت واحد من DATA__ = لا يُطلق أي إنذار
- الكود نفسه يكتب 0 هنا (آلية الموت البطيء) — لا يمكن التمييز

• لا أي دالة أخرى تراقب قيمة هذا البايت أو تتحقق منه

كيف نحصّن؟

1. إلغاء آلية الموت البطيء — استبدالها بـ exponential backoff بلا حد أقصى
2. حماية البايت بـ vm_protect (VM_PROT_READ) بعد التهيئة
3. نسخ mirror: تخزين القيمة في 3 مواقع عشوائية + majority vote
4. heartbeat من السيرفر: إذا لم يستلم تقارير لمدة 60 ثانية → إنذار

3

0x0376a0 — الموزّع الرئيسي (Main Router)

بوابة واحدة لكل الأحداث

SPOF

CRITICAL

ما هي هذه الدالة؟

هذه هي **البوابة الرئيسية** التي تمر عبرها كل الأحداث الأمنية بعد التهيئة. تحتوي جدول بوابات من 7 slots عند 0x29bc10. كل نوع حدث (event_id من 0 إلى 6) يمر عبر slot واحد. إذا slot = 0 → الحدث يُسقط بصمت.

سلسلة السيطرة الكاملة

AnoSDKInit → sub_0376a0 → sub_0373e8 → sub_0371e0 → COREREPORT → Server

كل شيء يمر عبر هذه السلسلة — تعطيل أي حلقة = انقطاع كامل

الدليل

```
=== الموزّع الرئيسي - sub_0376a0 ===  
  
0x0376b8: bl    sub_0370d0    ← تهيئة/فحص أولي  
0x0376bc: cmp   w20, #6        ← event_id > 6?  
0x0376c0: b.hi  #0x376d4        ← نعم - خروج صامت (حدث غير معروف)  
  
0x0376c8: add   x9, x9, #0xc10    ← x9 = 0x29bc10 = عنوان gate table  
0x0376cc: ldr   w8, [x9, w20, uxtw #2] ← قراءة slot[event_id]  
0x0376d0: cbz   w8, #0x376e4      ← خروج صامت → slot == 0  
                                trace ولا log الحدث يختفي - لا  
  
0x0376d4: ret                    ← slot ≠ 0 أو event_id > 6 خروج إذا
```

364 دالة downstream — كلها تموت

إذا تعطلت هذه الدالة، 364 دالة في شجرة الاستدعاء تصبح ميتة — تشمل:

- sub_0373e8 (بوابة الإبلاغ)
- sub_0371e0 (تسجيل القناة)
- 7 دوال init فرعية (#1-#7 subsystem init)
- كل دوال COREREPORT

هل يُكتشف؟

لا — لا integrity check لكود الدالة، ولا integrity check لجدول البوابات عند 0x29bc10. الجدول في __DATA (rw-) بدون حماية.

4

0x0a1414 — بوابة Syscall الخام

540 دالة تعتمد عليها

SPOF

HIGH

ما هي؟

هذه هي بوابة ال syscall المباشر — تتجاوز libc لمنع hooking. 13 تعليمة فقط. تستخدمها 9 دوال مباشرة (send, recv, ...connect) و 540 دالة بشكل غير مباشر.

=== مباشرة (13 تعليمة) syscall بوابة - sub_0a1414 === ;

```
0x0a1414: ldp x1, x2, [sp]      ← syscall args
0x0a1418: ldp x3, x4, [sp, #0x10]
0x0a141c: ldp x5, x6, [sp, #0x20]
0x0a1420: ldr x7, [sp, #0x30]
0x0a1424: mov x16, #0          ← syscall number (يُمرر مسبقاً)
0x0a1428: svc #0x80            ← المباشر syscall الـ
0x0a142c: b.lo #0xa1444        ← نجاح = carry clear
0x0a1438: bl sub_0a13ec        ← (errno) معالج خطأ
0x0a1444: ret                 ← رجوع
```

لماذا هي خطيرة؟

- 13 تعليمة فقط — سطح هجوم صغير لكن بدون أي حماية ذاتية
- obfuscation — التعليمات واضحة ومباشرة
- self-check — لا فحص سلامة لكود البوابة
- إذا تعطلت → كل الاتصالات تعود لـ libc العادي → قابلة لل hook

Flag التحكم — 0x2ab430

=== sub_0f8210 (transport_send) داخل === ;

```
0x0f8230: ldr w8, [x8, #0x430] ← 0x2ab430 من 0 flag قراءة
0x0f8234: tbnz w8, #0xd, #0xf824c ← مباشر syscall مفعّل → استخدم bit 13
0x0f8244: bl _send              ← libc مطفأً → استخدم bit 13 (hookable!)
0x0f825c: bl sub_0a1414         ← (syscall) المسار المباشر
```

Flag واحد عند 0x2ab430 (13 bit للإرسال، 14 bit للاستقبال) يتحكم بهل يستخدم النظام syscall مباشر أو libc. هذا flag في __DATA بدون حماية.

هل يُكتشف؟

لا — لا integrity check لكود البوابة. لا مراقبة لقيمة flag 0x2ab430. تحويل النقل من syscall إلى libc يحدث بصمت.

7 × 4 بايت = 28 بايت تتحكم بكل شيء

DATA

HIGH

ما هو؟

جدول من 7 كلمات bit-32 (28 بايت) في __DATA عند 0x29bc10. كل كلمة = بوابة لنوع حدث. إذا الكلمة = 0 → الحدث يُسقط. يُستخدم من قبل sub_0376a0 (الموَّع الرئيسي).

الفهرس	العنوان	الحجم	المعنى
slot[0]	0x29bc10	bytes 4	بوابة الحدث #0
slot[1]	0x29bc14	bytes 4	بوابة الحدث #1
slot[2]	0x29bc18	bytes 4	بوابة الحدث #2
slot[3]	0x29bc1c	bytes 4	بوابة الحدث #3
slot[4]	0x29bc20	bytes 4	بوابة الحدث #4
slot[5]	0x29bc24	bytes 4	بوابة الحدث #5
slot[6]	0x29bc28	bytes 4	بوابة الحدث #6

هل يُكتشف؟

لا — الجدول في __DATA (rw-). لا CRC، لا hash، لا vm_protect. تصفير slot واحد = إسقاط فئة كشف كاملة بصمت.

أوفست إضافي — Fail-Open الخطير

0x037004 — كاشف Debugger (Fail-Open)

Debugger

FAIL-OPEN

المشكلة الجوهرية

```

; === sub_037004 - فحص debugger عبر sysctl ===

0x03706c: bl    _sysctl          ← sysctl(KERN_PROC_PID) استدعاء
0x037070: cmn    w0, #1          ← هل رجع 1- (فشل)؟
0x037074: cset   w8, ne          ← w8 = (result ≠ -1) ? 1 : 0

0x037094: and    w9, w9, #0x800   ← عزل P_TRACED flag
0x037098: and    w0, w8, w9, lsr #11 ← w0 = success AND p_traced

; المشكلة:
; P_TRACED بغض النظر عن (w0 = 0 → w8 = 0 → فشل sysctl إذا)
; تنظيف "debugger" يعني "لا w0 = 0"
; "فشل الفحص" = "آمن" = FAIL-OPEN

```

الخطورة

منطق AND يعني: إذا فشل sysctl (رجع -1) → النتيجة = 0 = "لا debugger" بغض النظر عن الواقع. التصميم الصحيح: فشل sysctl = "مشتببه" (fail-closed).

الحكم النهائي – هل المهاجم يُكتشف؟

لا – المهاجم لا يُكتشف مطلقاً

لماذا؟ – 5 غيابات قاتلة

الآلية المطلوبة	موجودة؟	التأثير
فحص سلامة كود الدوال الحرجة (integrity check)	غائبة	تغيير كود الدالة بدون كشف
مراقبة الحالة العالمية (flag monitoring)	غائبة	تغيير flags بدون كشف
heartbeat من السيرفر	غائب	السيرفر لا يعرف أن التقارير توقفت
watchdog محلي	غائب	لا إنذار داخلي عند توقف الإبلاغ
قناة إبلاغ احتياطية	غائبة	نقطة فشل واحدة = صمت كامل

السبب الجذري

نظام ANOGS بُني على افتراض أن الكود لن يُعدّل. كل أنظمة الكشف (debugger, injection, jailbreak) تفحص البيئة الخارجية – لكن لا أي نظام يفحص سلامة كود الـ anti-cheat نفسه. هذا يعني: أنظمة الكشف تراقب كل شيء إلا نفسها.

خارطة التحمين – الأولويات

الأولوية	الإجراء	يحمي ضد
#1	إضافة heartbeat: السيرفر يتوقع تقارير دورية – غيابها = إنذار	صمت كامل بعد تعطيل الإبلاغ
#2	فحص سلامة كود الدوال الخمس الحرجة (hash check دوري)	تغيير كود الدوال
#3	حماية flags بـ vm_protect(READ) + نسخ mirror	تغيير flags في DATA__
#4	إلغاء آلية الموت البطيء (3 فشلات → تعطيل) واستبدالها بـ backoff	التعطيل الذاتي
#5	قناة إبلاغ ثانية مستقلة (بروتوكول مختلف، مسار كود مختلف)	SPOF في خط الإبلاغ
#6	تحويل debugger check من fail-open إلى fail-closed	إخفاء debugger عبر فشل sysctl
#7	obfuscation لبوابة syscall + self-integrity check	تعطيل النقل المباشر

